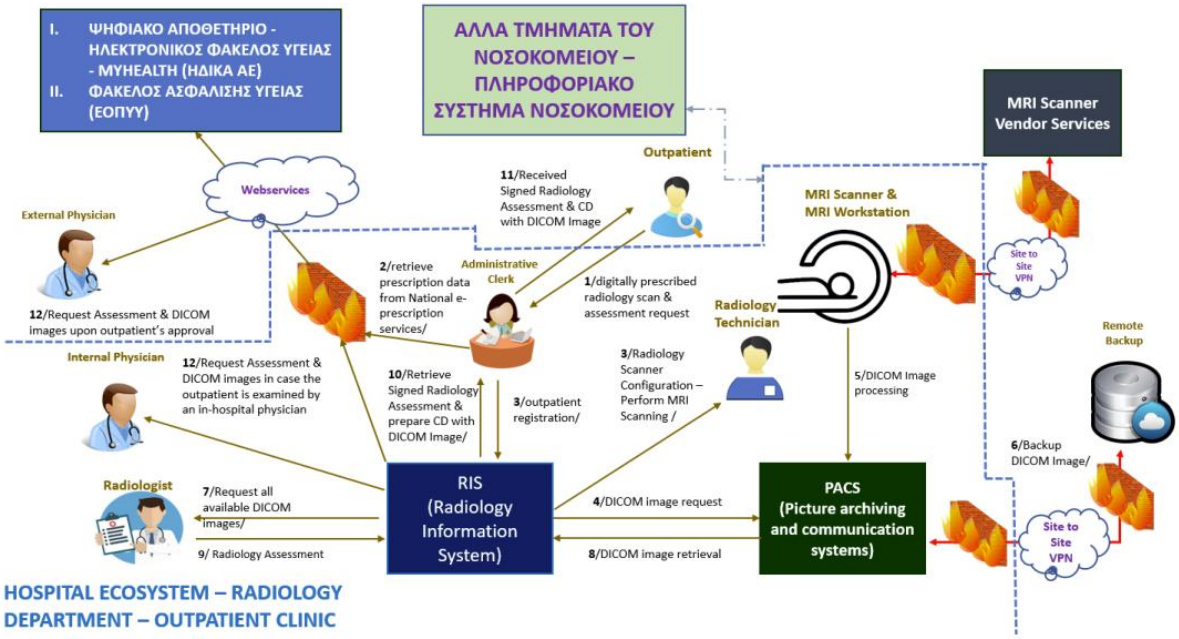
GOOGLE.ORG CYBERSECURITY SEMINARS

Aristotle University of Thessaloniki

Stergios Loukas

ΣΥΜΜΟΡΦΩΣΗ ΕΠΙΧΕΙΡΗΣΙΑΚΗΣ ΔΙΑΔΙΚΑΣΙΑΣ ΑΚΤΙΝΟΔΙΑΓΝΩΣΤΙΚΟΥ ΤΜΗΜΑΤΟΣ ΝΟΣΟΚΟΜΕΙΟΥ ΜΕ ΤΟΝ ΚΑΝΟΝΙΣΜΟ NIS2

Πολιτικές Ασφαλείας & Αντίστοιχα Τεχνικά Μέτρα



Πεδίο Εφαρμογής — Συστήματα, Εξωτερικές Συνδέσεις & Ρόλοι

Οι παρακάτω πολιτικές καλύπτουν το επιχειρησιακό οικοσύστημα του Ακτινοδιαγνωστικού Τμήματος, όπως προκύπτει από τη ροή εργασιών του νοσοκομείου.

Συστήματα που αποθηκεύουν ή/και επεξεργάζονται δεδομένα

- RIS (Radiology Information System)
- PACS (Picture Archiving and Communication System)
- MRI Scanner / Workstation
- Πληροφοριακό Σύστημα Νοσοκομείου (Hospital Information System)
- MyHealth (ΗΔΙΚΑ) / Φάκελος Ασφάλισης Υγείας (ΕΟΠΥΥ)

Εξωτερικές Συνδέσεις

- PACS ↔ Απομακρυσμένο Backup (Site-to-Site VPN)
- MRI Scanner/Workstation ↔ MRI Scanner Vendor Services (Site-to-Site VPN)
- Διοικητικός Υπάλληλος ↔ Εθνικές Υπηρεσίες e-Συνταγογράφησης / MyHealth (Webservices)
- RIS ↔ MyHealth (Webservices)
- Ακτινοδιαγνωστικό Τμήμα ↔ Λοιπά Τμήματα Νοσοκομείου

Ρόλοι

- Εξωτερικός Ασθενής (Outpatient)
- Διοικητικός Υπάλληλος (Administrative Clerk)
- Τεχνολόγος Ακτινολογίας (Radiology Technician)
- Ιατρός Ακτινολόγος (Radiologist)
- Εσωτερικός Ιατρός (Internal Physician)
- Εξωτερικός Ιατρός (External Physician)

i. ΠΟΛΙΤΙΚΗ ΕΛΕΓΧΟΥ ΠΡΟΣΒΑΣΗΣ & ΡΟΛΩΝ (ACCESS CONTROL POLICY)

Έκδοση: 1.0 | Ημερομηνία: 20/09/2026

1. Σκοπός

Η παρούσα πολιτική ορίζει τις αρχές και διαδικασίες για τη διαχείριση της πρόσβασης στα πληροφοριακά συστήματα του Ακτινοδιαγνωστικού Τμήματος, σύμφωνα με τις απαιτήσεις της Οδηγίας NIS2 για διαχείριση κινδύνου κυβερνοασφάλειας και ελέγχου πρόσβασης, με στόχο τη διασφάλιση ότι κάθε χρήστης έχει πρόσβαση μόνο στα δεδομένα και συστήματα που απαιτούνται για τον ρόλο του.

2. Πεδίο Εφαρμογής

Εφαρμόζεται σε	Όλο το προσωπικό και τα συστήματα του Ακτινοδιαγνωστικού Τμήματος
Χρήστες	Διοικητικός Υπάλληλος, Τεχνολόγος Ακτινολογίας, Ιατρός Ακτινολόγος, Εσωτερικός Ιατρός, Εξωτερικός Ιατρός, Εξωτερικός Ασθενής
Συστήματα / Εφαρμογές	RIS, PACS, MRI Scanner/Workstation, MyHealth
Υποδομές / Δίκτυα	Εσωτερικό δίκτυο νοσοκομείου, VPN συνδέσεις προς Remote Backup και MRI Vendor Services

3. Αρχές Ελέγχου Πρόσβασης — Ελάχιστο Απαιτούμενο Δικαίωμα (Least Privilege)

- Εξωτερικός Ασθενής: μόνο υποβολή αιτήματος προς τον Διοικητικό Υπάλληλο (mail/σύστημα ραντεβού).
- Διοικητικός Υπάλληλος: πρόσβαση σε δεδομένα εγγραφής/ραντεβού του ασθενούς — χωρίς πρόσβαση στην ιατρική αξιολόγηση ή τις εικόνες DICOM.
- Τεχνολόγος Ακτινολογίας: πρόσβαση στο MRI Scanner/Workstation και στα δεδομένα εγγραφής του εξεταζόμενου ασθενούς.
- Ιατρός Ακτινολόγος: πλήρης πρόσβαση στις εικόνες DICOM μέσω RIS, δικαίωμα υποβολής αξιολόγησης στο RIS, καθώς και πρόσβαση σε βασικά δεδομένα εγγραφής ασθενούς.
- Εσωτερικός Ιατρός: υπό όρους πρόσβαση στις εικόνες DICOM (RIS) — μόνο εφόσον ο ασθενής εξετάζεται εντός του νοσοκομείου (attribute-based access, συνδεδεμένη με την κατάσταση νοσηλείας).
- Εξωτερικός Ιατρός: υπό όρους πρόσβαση στην αξιολόγηση και τις εικόνες DICOM μέσω MyHealth — μόνο κατόπιν ρητής συγκατάθεσης του ασθενούς (consent-based access).

MFA για ευαίσθητα συστήματα: ☒ Ναι ☐ Όχι

Εφαρμόζεται σε όλα τα συστήματα που είναι προσβάσιμα εξωτερικά (άμεσα ή μέσω VPN): MyHealth, Απομακρυσμένο Backup, PACS, RIS, MRI Scanner/Workstation.

4. Διαδικασία Δημιουργίας / Τροποποίησης / Απενεργοποίησης Λογαριασμών Προσωπικού

Αίτηση πρόσβασης	Υποβάλλεται από τον προϊστάμενο τμήματος για κάθε νέο μέλος προσωπικού
Έγκριση από	Τμήμα IT/Ασφάλειας ΚΑΙ τον προϊστάμενο τμήματος του υπαλλήλου (διπλή έγκριση)
Χρόνος απενεργοποίησης μετά από αποχώρηση	Άμεσα — ο λογαριασμός καταργείται τη στιγμή που ο υπάλληλος παύει να απασχολείται στο νοσοκομείο
Ετήσια αναθεώρηση ρόλων	☒ Ναι — Συχνότητα: Ετησίως

5. Έλεγχος Πρόσβασης σε Δεδομένα ανά Περιστατικό

Επίπεδα πρόσβασης	Read-only (εικόνες/αξιολόγηση) ή Read-write (καταχώρηση αξιολόγησης) ανάλογα με τον ρόλο
Διαδικασία έγκρισης πρόσβασης σε ευαίσθητα δεδομένα — Εσωτερικός Ιατρός	Αυτόματη εξουσιοδότηση μόνο εφόσον ο ασθενής είναι καταχωρημένος ως εξεταζόμενος στο νοσοκομείο
Διαδικασία έγκρισης πρόσβασης σε ευαίσθητα δεδομένα — Εξωτερικός Ιατρός	Απαιτείται ρητή έγκριση/συγκατάθεση από τον ασθενή· η πρόσβαση ανακαλείται όποτε ο ασθενής το αποφασίσει

6. Καταγραφή & Παρακολούθηση

Τι καταγράφεται (logs)	Κάθε προσπάθεια σύνδεσης, προβολή/τροποποίηση εικόνων DICOM ή ιατρικών δεδομένων, εγκρίσεις/ανακλήσεις πρόσβασης
Χρόνος διατήρησης	Σύμφωνα με τις κανονιστικές απαιτήσεις τήρησης ιατρικών αρχείων (ελάχ. σύμφωνα με εθνική νομοθεσία υγείας)

7. Εξαιρέσεις / Ειδικές Περιπτώσεις

Δεν προβλέπονται εξαιρέσεις για ευαίσθητα δεδομένα ασθενών (DICOM εικόνες, ιατρικές αξιολογήσεις) — κάθε πρόσβαση υπόκειται στους παραπάνω κανόνες, ανεξαρτήτως ρόλου ή βαθμού επείγοντος.

ii. ΠΟΛΙΤΙΚΗ ΔΙΑΧΕΙΡΙΣΗΣ ΕΝΗΜΕΡΩΣΕΩΝ (PATCH MANAGEMENT)

Έκδοση: 1.0 | Ημερομηνία: 20/09/2026

1. Σκοπός

Η παρούσα πολιτική εξασφαλίζει ότι όλα τα συστήματα (servers, endpoints, δικτυακές συσκευές κ.λπ.) του Ακτινοδιαγνωστικού Τμήματος ενημερώνονται εγκαίρως για την αντιμετώπιση ευπαθειών, με προτεραιοποίηση βάσει κρισιμότητας συστήματος και σοβαρότητας ευπάθειας, σύμφωνα με τις απαιτήσεις διαχείρισης κινδύνου της NIS2.

2. Πεδίο Εφαρμογής & Κρισιμότητα Συστημάτων

RIS	Κρίσιμο (Critical) — διακοπή λειτουργίας εμποδίζει ολόκληρη τη ροή διάγνωσης
PACS	Κρίσιμο (Critical) — διακοπή λειτουργίας εμποδίζει τη διακίνηση εικόνων DICOM
MRI Scanner / Workstation	Κρίσιμο (Critical) — κίνδυνος για τη φυσική ασφάλεια του ασθενούς, πλήρης διακοπή σαρώσεων
Πληροφοριακό Σύστημα Νοσοκομείου	Μεσαίο (Medium) — δεν εμπλέκεται άμεσα στη ροή διάγνωσης/θεραπείας
Συστατικά προσβάσιμα από MyHealth	Υψηλό (High) — εξωτερικά εκτεθειμένα, μεγαλύτερη επιφάνεια επίθεσης

3. Συχνότητα Ενημερώσεων

Κρίσιμες / επείγουσες ενημερώσεις ευπαθειών (ανά επίπεδο σοβαρότητας ευπάθειας):

- Critical: αποκατάσταση εντός 24–72 ωρών από τη δημοσίευση της ενημέρωσης
- High: αποκατάσταση εντός 72 ωρών έως 1 εβδομάδας
- Medium: αποκατάσταση εντός 1 μήνα
- Low: αποκατάσταση εντός του τρέχοντος εξαμήνου/τριμήνου (term)

Τακτικές (routine) ενημερώσεις ανά βαθμίδα κρισιμότητας συστήματος:

- Κρίσιμα συστήματα (RIS, PACS, MRI Scanner/Workstation): Εβδομαδιαία
- Υψηλής κρισιμότητας (MyHealth-facing): Μηνιαία
- Μεσαίας κρισιμότητας (Hospital IS): Ανά δίμηνο
- Χαμηλής κρισιμότητας: Ανά εξάμηνο/τρίμηνο (term)

4. Διαδικασία Εντοπισμού Ευπαθειών

Εργαλεία που χρησιμοποιούνται	Αυτοματοποιημένα εργαλεία σάρωσης ευπαθειών (vulnerability scanners) σε τακτική βάση • Tenable Nessus • Qualys VMDR • Microsoft Defender Vulnerability Management (σε περίπτωση που το νοσοκομείο βασίζεται σε Windows infrastructure)
Πηγή ενημερώσεων	Επίσημες ανακοινώσεις κατασκευαστών/προμηθευτών λογισμικού, βάσεις δεδομένων γνωστών ευπαθειών (CVE) • cve.org • nvd.nist.gov • CERT.GR

	• Ανακοινώσεις προμηθευτή εξοπλισμού • ICS-CERT / CISA advisories

5. Διαδικασία Εφαρμογής (Testing / Staging)

- Η ενημέρωση εφαρμόζεται πρώτα σε περιβάλλον δοκιμών/staging (αντίγραφο συστήματος).
- Λειτουργική επαλήθευση — έλεγχος ότι το σύστημα λειτουργεί κανονικά μετά την ενημέρωση.
- Τεκμηρίωση σχεδίου επαναφοράς (rollback plan) πριν την ανάπτυξη σε παραγωγή.
- Απαιτείται έγκριση (sign-off) από το Τμήμα IT/Ασφάλειας πριν τη μετάβαση σε παραγωγή.
- Ανάπτυξη σε προγραμματισμένο παράθυρο συντήρησης (maintenance window), εκτός ενεργών κλινικών ωρών.

6. Καταγραφή

Σημειώνονται όλα τα patches στο: ☒ Έγγραφο ☐ Excel ☐ Άλλο — με ημερομηνία εφαρμογής, σύστημα, αποτέλεσμα δοκιμής και υπεύθυνο έγκρισης.

7. Εξοπλισμός υπό Διαχείριση Προμηθευτή (MRI Scanner)

- Ο προμηθευτής (MRI Scanner Vendor Services) είναι υπεύθυνος για την εφαρμογή ενημερώσεων στο δικό του εξοπλισμό.
- Ο προμηθευτής υποχρεούται να ειδοποιεί το νοσοκομείο εκ των προτέρων πριν από κάθε ενημέρωση.
- Ο προμηθευτής υποχρεούται να επιβεβαιώνει ότι η ενημέρωση δεν ακυρώνει την πιστοποίηση ασφαλείας/κανονιστικής συμμόρφωσης της ιατρικής συσκευής.
- Η ενημέρωση προγραμματίζεται εκτός κλινικού ωραρίου λειτουργίας.
- Το Τμήμα IT του νοσοκομείου ενημερώνεται ή παρίσταται, και λαμβάνει αποτελέσματα επικύρωσης μετά την εφαρμογή.

iii. ΠΟΛΙΤΙΚΗ ΓΙΑ DATA-AT-REST ΑΣΦΑΛΕΙΑ (ΕΜΠΙΣΤΕΥΤΙΚΟΤΗΤΑ, ΑΚΕΡΑΙΟΤΗΤΑ, ΔΙΑΘΕΣΙΜΟΤΗΤΑ)

Έκδοση: 1.0 | Ημερομηνία: 20/09/2026

1. Σκοπός

Προστασία των δεδομένων ασθενών (εικόνες DICOM, ιατρικές αξιολογήσεις, δεδομένα εγγραφής) που αποθηκεύονται σε servers, βάσεις δεδομένων (RIS, PACS), endpoints, φορητά μέσα και το MyHealth repository, διασφαλίζοντας εμπιστευτικότητα, ακεραιότητα και διαθεσιμότητα σύμφωνα με τις απαιτήσεις της NIS2 και τον ΓΚΠΔ (GDPR) για ευαίσθητα δεδομένα υγείας.

2. Πεδίο Εφαρμογής

Συστήματα	RIS, PACS, MyHealth repository, τοπικοί σταθμοί εργασίας
Βάσεις δεδομένων	Βάσεις δεδομένων ασθενών RIS/PACS
Αρχεία / Backups	Εικόνες DICOM, ιατρικές αξιολογήσεις, αντίγραφα ασφαλείας στον Απομακρυσμένο χώρο Backup

3. Εμπιστευτικότητα (Confidentiality)

Κρυπτογράφηση σε αποθήκευση	☒ Ναι — AES-256, εφαρμόζεται σε όλες τις εικόνες DICOM και τα δεδομένα ασθενών
Key management	Τα κλειδιά κρυπτογράφησης διαχειρίζονται αποκλειστικά από το Τμήμα IT του νοσοκομείου — ποτέ από εξωτερικούς προμηθευτές
Πρόσβαση περιορισμένη σε χρήστες	Σύμφωνα με την Πολιτική Ελέγχου Πρόσβασης & Ρόλων (βλ. ενότητα i)

4. Ακεραιότητα (Integrity)

Hashing / Checksum	Κάθε εικόνα DICOM και ιατρική εγγραφή αποθηκεύεται με κρυπτογραφικό hash για ανίχνευση αλλοίωσης/διαφθοράς δεδομένων
Σημείο επαλήθευσης hash	Το hash επαληθεύεται εκ νέου σε κάθε αίτημα πρόσβασης, ώστε να αποτρέπεται η χρήση αλλοιωμένων δεδομένων (π.χ. αξιολόγηση από ιατρό βάσει λάθος εικόνας)
Logging αλλαγών αρχείων	☒ Ναι — κάθε μεταβολή αρχείου καταγράφεται
Παρακολούθηση μη εξουσιοδοτημένων αλλαγών	Το Τμήμα IT παρακολουθεί τα logs για εντοπισμό μη εξουσιοδοτημένων τροποποιήσεων

5. Διαθεσιμότητα (Availability)

Backups	☒ Ημερήσιο, με συνεχή (continuous) αντιγραφή προς τον απομακρυσμένο χώρο Backup
Redundancy	Συνεχής αναπαραγωγή δεδομένων (real-time replication) προς τον Remote Backup μέσω Site-to-Site VPN
RTO (Recovery Time Objective)	< 90 λεπτά — αντιστοιχεί στη μέγιστη διάρκεια μιας νέας εξέτασης MRI

RPO (Recovery Point Objective)	0 — μηδενική ανοχή απώλειας δεδομένων λόγω της ευαίσθητης φύσης των ιατρικών αρχείων, εξασφαλισμένη μέσω συνεχούς αναπαραγωγής

iv. ΠΟΛΙΤΙΚΗ ΓΙΑ DATA-IN-TRANSIT ΑΣΦΑΛΕΙΑ

Έκδοση: 1.0 | Ημερομηνία: 20/09/2026

1. Σκοπός

Διασφάλιση ότι όλα τα δεδομένα κατά τη μεταφορά — εντός του εσωτερικού δικτύου του νοσοκομείου και προς εξωτερικά συστήματα (MyHealth, MRI Vendor, Remote Backup) — είναι κρυπτογραφημένα και προστατευμένα από μη εξουσιοδοτημένη πρόσβαση, σύμφωνα με τις αρχές zero-trust που προωθεί η NIS2.

2. Τεχνολογίες Κρυπτογράφησης

TLS έκδοση	TLS 1.3 σε όλες τις web-facing συνδέσεις (π.χ. Διοικητικός Υπάλληλος ↔ MyHealth/e-συνταγογράφηση, RIS ↔ MyHealth)
VPN	☒ WireGuard — επιλέγεται λόγω απλούστερου, ελεγχόμενου κώδικα (μικρότερη επιφάνεια επίθεσης έναντι IPSec) και καλύτερης απόδοσης/χαμηλότερης καθυστέρησης, κρίσιμης για τη σχεδόν πραγματικού χρόνου μεταφορά εικόνων DICOM
Εσωτερική κρυπτογράφηση υπηρεσιών (service-to-service)	End-to-end κρυπτογράφηση TLS 1.3 και εντός του εσωτερικού δικτύου (π.χ. RIS ↔ PACS), με βάση αρχές zero-trust και need-to-know, χωρίς να θεωρείται το εσωτερικό δίκτυο εγγενώς έμπιστο

3. Σημεία Μεταφοράς Δεδομένων

Εσωτερικό δίκτυο	RIS ↔ PACS, Ακτινοδιαγνωστικό Τμήμα ↔ λοιπά τμήματα νοσοκομείου — κρυπτογραφημένα με TLS 1.3
Cloud / Απομακρυσμένο Backup	Site-to-Site VPN (WireGuard) προς Remote Backup
API / Integrations	RIS ↔ MyHealth, Διοικητικός Υπάλληλος ↔ Εθνικές Υπηρεσίες e-Συνταγογράφησης, μέσω Webservices με TLS 1.3

4. Έλεγχος Ταυτότητας & Πρόσβασης

MFA για απομακρυσμένη πρόσβαση	☒ Ναι
Certificate-based authentication	☒ Ναι — για όλες τις εξωτερικές διασυνδέσεις συστημάτων (site-to-site VPN προς MRI Vendor και Remote Backup)

Αιτιολόγηση διπλού ελέγχου ταυτότητας: τα πιστοποιητικά (certificates) επαληθεύουν το συνδεόμενο σύστημα/συσκευή (π.χ. ότι πρόκειται όντως για τον server του προμηθευτή MRI), ενώ το MFA επαληθεύει τον συγκεκριμένο χρήστη που το χειρίζεται — ο συνδυασμός τους αποτρέπει τόσο την πλαστοπροσωπία συσκευής όσο και την κλοπή διαπιστευτηρίων.

5. Παρακολούθηση

IDS/IPS	Ανάπτυξη σε κάθε πύλη (gateway) προς εξωτερικά συστήματα
TLS inspection	Επιθεώρηση TLS μόνο στο επίπεδο της πύλης VPN/firewall, όπου το νοσοκομείο ελέγχει και τα δύο άκρα της σύνδεσης — χωρίς βαθιά επιθεώρηση περιεχομένου που θα έθετε σε κίνδυνο την εμπιστευτικότητα end-to-end των δεδομένων ασθενών

v. ΠΟΛΙΤΙΚΗ ΚΑΤΑΤΜΗΣΗΣ ΔΙΚΤΥΟΥ & ΑΣΦΑΛΟΥΣ ΠΡΟΣΒΑΣΗΣ ΕΦΟΔΙΑΣΤΙΚΗΣ ΑΛΥΣΙΔΑΣ

Έκδοση: 1.0 | Ημερομηνία: 20/09/2026

1. Σκοπός

Ορισμός των μέτρων για δικτυακό διαχωρισμό (network segmentation) και για ασφαλή διασύνδεση τρίτων (προμηθευτών, συνεργατών), περιορίζοντας την επιφάνεια επίθεσης και την πλευρική κίνηση (lateral movement) εντός του δικτύου του νοσοκομείου, σύμφωνα με τις απαιτήσεις της NIS2 για ασφάλεια εφοδιαστικής αλυσίδας.

2. Κατάτμηση Δικτύου

Ζώνη MRI Scanner/Workstation	Απομονωμένη ζώνη (κρίσιμο σημείο) — δεν μοιράζεται δίκτυο με γενικά διοικητικά συστήματα
Ζώνη RIS – PACS	Κοινό τμήμα δικτύου αφιερωμένο στη ροή διαγνωστικών δεδομένων
Ζώνη Πληροφοριακού Συστήματος Νοσοκομείου (Hospital IS)	Ξεχωριστή, αυτοτελής ζώνη
DMZ	Περιλαμβάνει όλα τα συστατικά που επικοινωνούν με το MyHealth· εκεί τερματίζει και η σύνδεση VPN του προμηθευτή MRI (Vendor VPN) — όχι απευθείας εντός της ζώνης MRI

3. Κανόνες Επικοινωνίας Μεταξύ Ζωνών

- Προεπιλεγμένος κανόνας: Deny all by default — επιτρέπεται μόνο η ρητά απαιτούμενη κίνηση μεταξύ ζωνών.
- Η απευθείας επικοινωνία PACS ↔ Πληροφοριακό Σύστημα Νοσοκομείου δεν επιτρέπεται.

4. Firewall & Access Rules

Change control διαδικασία	Κάθε αλλαγή κανόνα firewall απαιτεί τεκμηριωμένη έγκριση πριν την εφαρμογή· εκτελείται αποκλειστικά από ανώτερο στέλεχος του Τμήματος IT — δεν επιτρέπονται αυτόνομες αλλαγές από απλό προσωπικό IT

5. Ασφαλής Πρόσβαση Προμηθευτών (Supply Chain)

Προμηθευτές που χρειάζονται πρόσβαση	MRI Scanner Vendor Services
Τύποι πρόσβασης	Περιορισμένη (scoped) πρόσβαση αποκλειστικά στο σύστημα MRI — όχι πλήρης πρόσβαση VPN στο εσωτερικό δίκτυο
Χρονικός περιορισμός	Πρόσβαση ενεργή μόνο κατά τη διάρκεια προγραμματισμένων παραθύρων συντήρησης (time-boxed access), όχι μόνιμα ενεργή (always-on)
MFA	☒ Ναι
Περιορισμός ωραρίου πρόσβασης	☒ Ναι — εκτός κλινικού ωραρίου λειτουργίας
Monitor logs τρίτων	Όλη η δραστηριότητα του προμηθευτή κατά τη σύνδεση καταγράφεται και παρακολουθείται από το Τμήμα IT